

CSW Posture Brief — customer1

One-page board update generated 2026-05-01T18:30:00Z. Source: live evidence bundle from <https://csw.customer1.example>.

Posture score

29 / 100 (F)

Component	Score	What it means
Visibility	16 / 25	1206/1880 workloads reporting (64.1% agent coverage).
Segmentation	6 / 30	84 policies, 22 in enforce mode (26%), 4 absolute (5%).
Hygiene	3 / 20	19 critical, 142 high CVEs detected on workloads.
Operations	1 / 15	187 enforcement alerts in last 24h.
Compliance	3 / 10	7/25 controls marked 'met' across 4 frameworks.

What's working (1)

- Evidence collected for 4 frameworks.** Re-using a single set of CSW evidence across multiple frameworks is the headline value proposition - this tenant is realising it. *Reinforces:* HIPAA (2); PCI-DSS (1); NIST-800-53 (3); SOC2 (1).

Where to focus next (5)

Compliance reach. Addressing the items below would help close ~33 **not-yet-met controls** across **4 frameworks** (HIPAA, PCI-DSS, NIST-800-53, SOC2). The "Affects" column lists the framework and the count of controls per row.

#	Risk	Category	Impact	Affects
1	62 policies remain in monitor mode — Monitor-	segmentation	+11 pts	HIPAA (3); PCI-DSS (2); NIST-800-53 (5); SOC2 (2)

#	Risk	Category	Impact	Affects
	mode policies generate evidence but do not block lateral movement. Promoting reviewed policies to enforce directly improves the segmentation score component.			
2	674 workloads without an agent — Workloads outside agent coverage are invisible to flow analytics, ADM, and policy enforcement. Closing this gap unlocks visibility-driven controls in every framework.	visibility	+9 pts	HIPAA (1); PCI-DSS (1); SOC2 (2)
3	19 critical CVEs on workloads — CSW correlates package CVEs to running processes.	hygiene	+9 pts	PCI-DSS (2)

#	Risk	Category	Impact	Affects
	Each critical CVE on an internet-reachable workload is a candidate for escalation to patching or compensating policy.			
4	Few absolute policies in place — Absolute policies are the right tool for crown-jewel isolation (PHI, cardholder data, regulated systems). Their absence indicates the segmentation strategy is still permissive-by-default.	segmentation	+6 pts	HIPAA (3); PCI-DSS (2); NIST-800-53 (5); SOC2 (2)
5	187 enforcement alerts in 24h — Sustained alert volume indicates either policy gaps (legitimate flows blocked) or active attack pressure. Both warrant	operations	+5 pts	HIPAA (1); PCI-DSS (1); SOC2 (1)

#	Risk	Category	Impact	Affects
	SOC engagement and policy review.			

30-day plan

Wk	Action	Owner
1	Close agent-coverage gap. Identify the 674 workloads without an agent. Triage into: (a) deploy now, (b) excluded by policy, (c) decommission. Track in a single ticket; aim for 95%+ coverage.	Platform Engineering
2	Promote vetted policies to enforce mode. Run the 30-day flow review on monitor-mode policies for top 3 scopes. Promote those with no false-positive flow violations to enforce.	Security Operations
3	Author absolute policies for crown jewels. Identify the top 3 crown-jewel scopes (databases of regulated data, payment systems, PHI stores). Draft absolute policies that take precedence over inherited rules.	Security Architecture
4	Address top critical CVEs. Pull the CSW vulnerability dashboard, sort by internet exposure + severity, dispatch top 10 to patching or compensating-policy workstreams.	Vulnerability Management

Wk	Action	Owner
5	Tune enforcement alert noise. Categorise the past 24h of alerts (legitimate block, missing exception, real attack). Build exception rules for the first two; route the third into incident response.	Security Operations
6	Refresh evidence and report. Re-run csw-insights against the tenant. Compare posture score to baseline; share delta with steering committee.	Compliance / GRC

Compliance posture across frameworks

Framework	Controls evaluated	Met	Coverage
HIPAA	7	2	29%
PCI-DSS	6	1	17%
NIST-800-53	8	3	38%
SOC2	4	1	25%

Notes for the board pack

- **Source of truth.** Every number above is traceable to the underlying evidence bundle (evidence/customer1-2026-05-01.json) signed at collection time. Auditors get the bundle; the board gets this page.
- **Cadence.** Re-running csw-insights weekly produces the trend line; the recommended cadence for board updates is monthly.
- **What this is not.** A posture score is a management tool, not a compliance attestation. Refer to the framework runbooks in CSW-Compliance-Mapping for control-by-control evidence.